Codebase Security Audit Report

CUSTOMER	Coinversa
SCOPE	Backend & Frontend Codebase Security
DATE	17.03.2026

Made in Germany by softstack GmbH

Table of Contents

1. Disclaimer 3

2. About the Project and Company 4

3. Vulnerability & Risk Level 5

4. Auditing Strategy and Techniques Applied 6

5. Metrics 7

5.1 Tested Codebase Files 7

5.2 Source Lines & Risk 16

5.3 Dependencies / External Imports 16

5.4 Source Units in Scope 16

6. Scope of Work 24

6.1 Findings Overview 24

6.2 Manual and Automated Vulnerability Test 25

6.2.1 privyAuth GET Bypass: Inconsistent Auth Model 25

6.2.2 privyAuth No Ownership Check: Trading IDOR 26

6.2.3 Hardcoded PostgreSQL Credentials in Fallback Connection String 27

6.2.4 Notifications.jsx innerHTML XSS (Stored XSS Vector) 27

6.2.5 Canton Passkey Secret Stored Unencrypted in localStorage 28

6.2.6 Missing Security Hardening Middleware 29

6.2.7 JWT Tokens Never Expire 30

6.2.8 HTML Injection in Email Bodies 30

6.2.9 WebSocket No maxPayload Limit (DoS Risk) 31

6.2.10 Auth Tokens in localStorage (Session Theft Risk) 32

6.2.11 Vulnerable Dependencies: Backend (121 CVEs, 6 Critical) 32

6.2.12 Vulnerable Dependencies: Frontend (95 CVEs, 4 Critical) 33

6.2.13 Express X-Powered-By Header Disclosure 33

7. Executive Summary 35

8. About the Auditor 36

9. Glossary 37

1. Disclaimer

The audit makes no statements or warrantees about utility of the code, safety of the code, suitability of the business model, investment advice, endorsement of the platform or its products, regulatory regime for the business model, or any other statements about fitness of the codebase to purpose, or their bug free status. The audit documentation is for discussion purposes only.

The information presented in this report is confidential and privileged. If you are reading this report, you agree to keep it confidential, not to copy, disclose or disseminate without the agreement of the client. If you are not the intended receptor of this document, remember that any disclosure, copying or dissemination of it is forbidden.

Version / Date	Description
0.1 (10.03.2026)	Layout
0.5 (14.03.2026)	Manual & Automated Security Testing
0.9 (17.03.2026)	Summary and Recommendation
1.0 (17.03.2026)	Final document

2. About the Project and Company

Company: Coinversa Inc

Address: 1007 North Orange St., 4th Floor, Wilmington, Delaware 19801, USA

Website: https://www.coinversaa.ai

GitHub: https://github.com/Coinversaa

Coinversa provides infrastructure for on-chain trading, enabling users to analyze markets, coordinate multiple wallets, and execute trades directly from their own custody. The platform indexes clearinghouse state and trader activity in real time to power portfolio visibility, market intelligence, and coordinated execution across wallets.

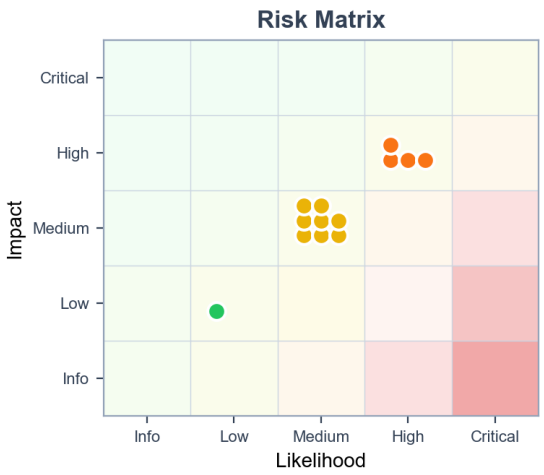
Trading activity is reconciled through a private identity layer anchored on the Canton Network, ensuring non-custodial execution while maintaining a unified coordination layer across connected wallets. The platform is designed for discretionary traders and systematic strategies, starting with Hyperliquid as the first supported venue.

The audited scope covers the full backend API (Express/TypeScript) and frontend application (React/JSX) that together form the Coinversa web platform. The backend handles authentication via Privy, trading execution through the Hyperliquid API, Canton ledger integration, WebSocket market data streaming, and PostgreSQL persistence. The frontend provides the trading interface, wallet management, Canton identity passkey handling, and notification system.

3. Vulnerability & Risk Level

Risk represents the probability that a certain source-threat will exploit vulnerability, and the impact of that event on the organization or system. Risk Level is computed based on CVSS version 3.1.

Level	CVSS Score	Vulnerability	Required Action
CRITICAL	9.0 – 10.0	A vulnerability that can disrupt the application functioning in a number of scenarios, or creates a risk that the application may be broken.	Immediate action to reduce risk level.
HIGH	7.0 – 8.9	A vulnerability that affects the desired outcome when using an application, or provides the opportunity to use an application in an unintended way.	Implementation of corrective actions as soon as possible.
MEDIUM	4.0 – 6.9	A vulnerability that could affect the desired outcome of executing the application in a specific scenario.	Implementation of corrective actions in a certain period.
LOW	0.1 – 3.9	A vulnerability that does not have a significant impact on possible scenarios for the use of the application and is probably subjective.	Implementation of certain corrective actions or accepting the risk.
INFORMATIONAL	0.0	A vulnerability that has informational character but is not affecting any of the code.	An observation that does not determine a level of risk.



4. Auditing Strategy and Techniques Applied

Throughout the review process, care was taken to evaluate the repository for security-related issues, code quality, and adherence to specification and best practices.

The auditing process follows a routine series of steps:

Code review that includes the following:

- Review of the specifications, sources, and instructions provided to softstack to make sure we understand the size, scope, and functionality of the frontend and backend codebase.
- Manual review of code, which is the process of reading source code line-by-line in an attempt to identify potential vulnerabilities.
- Comparison to specification, which is the process of checking whether the code does what the specifications, sources, and instructions provided to softstack describe.

Testing and automated analysis that includes the following:

- Test coverage analysis, which is the process of determining whether the test cases are actually covering the code and how much code is exercised when we run those test cases.
- Symbolic execution, which is analysing a program to determine what inputs causes each part of a program to execute.

Best practices review, which is a review of the codebase to improve efficiency, effectiveness, clarify, maintainability, security, and control based on the established industry and academic practices, recommendations, and research.

Specific, itemized, actionable recommendations to help you take steps to secure your codebase.

5. Metrics

The metrics section gives the reader an overview of the size, quality, flows and capabilities of the codebase.

5.1 Tested Codebase Files

Source repositories and commits for each codebase in scope:

Codebase	Source	Commit
Backend	https://github.com/Coinversaa/backend	`d070897d0a97ae02b5d9490d89841f5e66cccb21`
Frontend	https://github.com/Coinversaa/frontend	`0ef015361e92129409b17abee7b5ddcc2bc27305`

backend-audit

File	Fingerprint (MD5)
./backend-audit/mcp-server/src/index.ts	`f5071e05a2058666e317b43c669b561a`
./backend-audit/scripts/cantonContracts.ts	`91e77779215cdad86d0ecc028b935dda`
./backend-audit/scripts/createApiKey.ts	`4fda2303b3f26175099ef5f7fb2f821b`
./backend-audit/scripts/fetchPartyTransactions.ts	`d384bf4f75d68e6a36fb832797a7e7b2`
./backend-audit/scripts/fetchPendingDeposits.ts	`538d1bcdd0ec72b656e4e649cad371a2`
./backend-audit/scripts/generate-agent.js	`f4853afae79570213757d2dd9b8607fe`
./backend-audit/scripts/hyperliquidDepositTest.ts	`cc091c57c99ba16fad16373fc1c6e800`
./backend-audit/scripts/issuePoints.ts	`e23fff546777b539f04a414675873880`
./backend-audit/scripts/privyTest.ts	`7905f8304e02f734987d2640e0a70e1c`
./backend-audit/scripts/resetPassword.ts	`4be2202fd728e8d543ab4f4f6515367c`
./backend-audit/scripts/testCanton.ts	`f8e05a3bc16c31fcec41306d84dc1964`
./backend-audit/scripts/testHyperliquid.ts	`faf72015dc37ebf67d7c041561b0976e`
./backend-audit/scripts/testLifiHex.ts	`121bf8e78006783550709e0715b0bab1`
./backend-audit/scripts/testMetricData.ts	`723a9c03c3d3e09e18479588417b84a7`
./backend-audit/scripts/testsHyperliquidBridge.ts	`4299bf4af1fb17f69a0f02a662807442`

File	Fingerprint (MD5)
./backend-audit/src/alerts/api.ts	3335e34ac12c2ba84553b1ac8083ebf2
./backend-audit/src/alerts/bot.ts	55517e3afa3108a7ac989312071329b1
./backend-audit/src/alerts/index.ts	62e4409a8f5b830336296ec604c4b481
./backend-audit/src/alerts/storage.ts	d2eb1db6f51646533904cf1370bd2d38
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/index.d.ts	e629832ba88af0cd09d7572c5d7c6906
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/index.js	d577b9b543668728e6421835af170d0c
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/TermsAcceptance/index.d.ts	aa585350ec1e20bdac3af8fa3829671c
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/TermsAcceptance/index.js	28d5aa4febbbb01f73bf64fe05b256d9
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/TermsAcceptance/module.d.ts	e246ca7b7fb086ef02baf6349aa6d5c3
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/TermsAcceptance/module.js	fba200a85b6473bc4394e4c57f7fb703
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/Transaction/index.d.ts	aa585350ec1e20bdac3af8fa3829671c
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/Transaction/index.js	28d5aa4febbbb01f73bf64fe05b256d9
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/Transaction/module.d.ts	4b860fd493885b5f5bc2a6a9df52d102
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/Transaction/module.js	6e02c41e55da149c5c307d5f39b1090d
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/Types/index.d.ts	aa585350ec1e20bdac3af8fa3829671c
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/Types/index.js	28d5aa4febbbb01f73bf64fe05b256d9
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/Types/module.d.ts	a5657ddedf21b86432336b587efd605d
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/Types/module.js	1be94f66fa7ad37a6f2144ddd09870cd
	aa585350ec1e20bdac3af8fa3829671c

File	Fingerprint (MD5)
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/UserIdentity/index.d.ts	
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/UserIdentity/index.js	28d5aa4febbbb01f73bf64fe05b256d9
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/UserIdentity/module.d.ts	898616dccc260b723bad94f1fe457aca
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Coinversaa/UserIdentity/module.js	2f5873e80c3e8a236a2045a166f3e329
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/index.d.ts	6a6f5cc2891b8d8fb618b882e1d41fcc
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/index.js	fc63ab6e6f0faec5910842dd1082b78f
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Test/index.d.ts	aa585350ec1e20bdac3af8fa3829671c
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Test/index.js	28d5aa4febbbb01f73bf64fe05b256d9
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Test/module.d.ts	214a992d51e5a5b4642b5f1e28f79369
./backend-audit/src/bindings/daml-js/coinversaa-contract-v5-0.1.0/lib/Test/module.js	32961f36bd1910587f54ee439999bc0b
./backend-audit/src/canton/apis/schema.d.ts	3db1d36aba9df094d98b8c611a629c05
./backend-audit/src/canton/apis/validator-schema.d.ts	e7d341c4c72493892be924a989da8ce1
./backend-audit/src/canton/cantonService.ts	16632aab10f857955dab3926480a0cbc
./backend-audit/src/canton/quests.ts	73995734e2510afa5aaa76abbd5001db
./backend-audit/src/canton/rewards.ts	bd2f9286624369b2893e931035eedcdd
./backend-audit/src/captcha.ts	37a8657ab4ef45bb33a310dc9c7cd25a
./backend-audit/src/commands/commands.ts	17364be2bf4726968a9fca7da98f572c
./backend-audit/src/commands/definitions.ts	aa91ad65c6961cf111700617e7ca1fbc
./backend-audit/src/commands/hyperDefinitions.ts	ea90bbc36769ce040070df7fb72e6407
./backend-audit/src/commands/types.ts	83002061fcf5003333303485578874f9
./backend-audit/src/crypto/blockchainService.ts	6d6846ea65603acd27cc1a8d8ce79423

File	Fingerprint (MD5)
./backend-audit/src/crypto/bridge.ts	cc8ebba532df5e6723bb9b50886f358d
./backend-audit/src/crypto/chainConfig.ts	0843920d05ae57cfe7996dcb6ad82af2
./backend-audit/src/crypto/db.ts	3c4d2dd80b9a4ecbd943f7ae1d32a891
./backend-audit/src/crypto/gcpLiveService.ts	c67a0ac5d6ee5f30366774b7fb5c439c
./backend-audit/src/crypto/hlpulseHistoricalService.ts	c4fef93eea5dc9f86d13a7d8abd9ced0
./backend-audit/src/crypto/hyperliquidDepositService.ts	5fed670d5d474d59e086240e0dae14fc
./backend-audit/src/crypto/hyperliquidService.ts	ed8a878c426088a929cec45361177cc7
./backend-audit/src/crypto/hyperliquidStatsService.test.ts	0c87ed0f38f4d40f94d1295f9f2a1c42
./backend-audit/src/crypto/hyperliquidStatsService.ts	63409ce928d16346d541750e4937e941
./backend-audit/src/crypto/hyperliquidWebSocket.ts	b87ae4d2cab20b000674e5706dad370b
./backend-audit/src/crypto/intervals.ts	b9d7f304c6c2936fd18c1485a70baa78
./backend-audit/src/crypto/lifi.ts	2fa4fac1370295b0d056415f9cd43b31
./backend-audit/src/crypto/setupWebSocket.ts	be2dab5df04faec9e723660f47054923
./backend-audit/src/crypto/tokens.ts	0a77a0a14116e4d4ebc5f163319bf89e
./backend-audit/src/crypto/types.ts	7d422e242b21f50cc80a911c83ad9cf2
./backend-audit/src/crypto/util.ts	decdbe86dcb14e2db8df58421e7f3d96
./backend-audit/src/db.ts	3ca3bb4be4178e5ad0fff305a4e9013b
./backend-audit/src/email.ts	27a86059025ffc3936148d836ec34905
./backend-audit/src/helpers/getVerifiedEmail.ts	0c16d1f5be76d0b3c6490d1a3c45708e
./backend-audit/src/index.ts	87d61163cf1a88c9b6f12b09918ffd21
./backend-audit/src/middleware/apiKeyAuth.ts	dcb4ba66dfd09a210cdbc6007d2c7e18
./backend-audit/src/middleware/privyAuth.ts	82a3476a2cc895507a1a283e8bf7cffb
./backend-audit/src/middleware/stagingAuth.ts	0ba6e08b45e96f4bde680735510ed0d6
./backend-audit/src/middleware/strictPrivyAuth.ts	310af2af1235eceba528960dfd7f64e7
./backend-audit/src/priceData.ts	5072fb4cccefd6f2812d98bf3ce41991
./backend-audit/src/privy.ts	e04bf9e619bf0241a9a3cd4c67e19c69
./backend-audit/src/routes.ts	cedfa7f69bb95366051dadbc8cbab862

File	Fingerprint (MD5)
./backend-audit/src/routes/cantonRoutes.ts	4de6fb65892190612d8343eaa0c0a6ea
./backend-audit/src/routes/developer/index.ts	3f1429481bc5d66e6b0242b4a6155e49
./backend-audit/src/routes/public/v1/index.ts	9297aa970ee6a40395caf7d38aa50bf7
./backend-audit/src/routes/stagingAuth.ts	e9867bc75cd51856e7496ef8407e1c8b
./backend-audit/src/routes/v1/hyperliquid/index.ts	996fea70e389829f57de46b6704aaef4
./backend-audit/src/routes/v1/hyperliquid/schemas.ts	0b6b0ca07c6dfdec63aa75e0dc60f6f1
./backend-audit/src/routes/v1/index.ts	65e885a16c2e1ecdff082fdb0cce59db
./backend-audit/src/routes/v1/live/index.ts	d61a0940e6e8249bf46913af6cdd0d65
./backend-audit/src/routes/v1/pulse/index.ts	05066a3724be53dd7199a98bf857959b
./backend-audit/src/telegram/telegram-bot.ts	0a8d2cf7c75f26865b583e683d14afcc
./backend-audit/src/telegram/telegram-daily.ts	b4ab1facbd7b588a051012bee4cba23f
./backend-audit/src/telegram/telegram-db.ts	abf51c884c3ec7ad84329bd349cafaa2
./backend-audit/src/util.ts	26cd0764e2a606a9736a5cb8c00e5f6a
./backend-audit/tests/points.test.ts	2a95342935bd1b601fdf0efef6d1854a
./backend-audit/tests/setup.ts	adaafa011b001b5ae81ae0b774dfd22e
./backend-audit/tests/sql_injection.ts	5466cd8768de637bfd0c2087b4808370
./backend-audit/tests/stress/api_stress_1k.ts	275ff208f408e77b3f4c4f2e9b15be97
./backend-audit/tests/stress/ws_stress_1k.ts	45db80aef7cf82bee76b97baa02993a5
./backend-audit/tests/test_no_auth_close_position.ts	3730f2a411b513341c549fe27eae21ba
./backend-audit/tests/test_privy_auth.ts	eb99adc423bf2078da1dea2fd4a7b08a

frontend-audit

File	Fingerprint (MD5)
./frontend-audit/eslint.config.js	2942b0578a4c41b7fe8139dcf341780f
./frontend-audit/src/AccountsView.jsx	4e6dfb0d5a0e3db95ff2d4d4a8d7c440
./frontend-audit/src/App.jsx	933b8f63c0d7473fcdab87ac77da1a11
./frontend-audit/src/AppLayout.jsx	b177a4335a6d2a2075d06845c48576c9

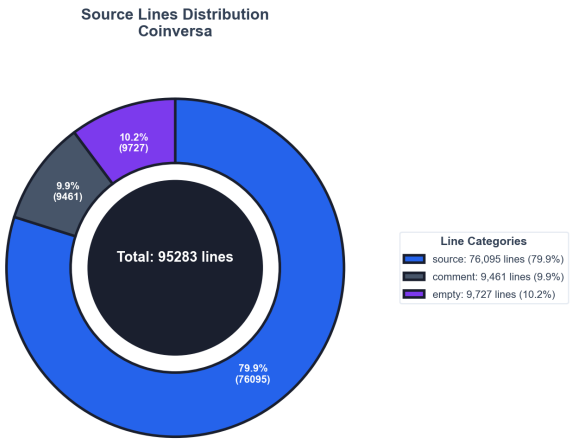
File	Fingerprint (MD5)
./frontend-audit/src/AppNavigation.jsx	af6d3bf5a8d864963873139db548a72f
./frontend-audit/src/ChainLogo.jsx	46ac2d23e7429a49cddc179a91dc3cb5
./frontend-audit/src/chains.config.js	8a28e2d2ecdeb21afaa55fd9761d78ed
./frontend-audit/src/Command.jsx	d98ecd29b250e40de9c0fa6a29cc8472
./frontend-audit/src/CommandBar.jsx	f9cd7540aa6b71daf4dfd1df5da56b21
./frontend-audit/src/commandParser.ts	e75a010f0b119b7b947dd470b271a2c4
./frontend-audit/src/components/CantonPartyId.tsx	1b7c80f2901a908e8fdd6509b85ffbbc
./frontend-audit/src/components/SolanaProvider.tsx	02fe48ed9ef238e8197182ae7ae8c039
./frontend-audit/src/components/Spinner.jsx	a541515fe7483d1ac7a069300f124058
./frontend-audit/src/ConnectedWallets.jsx	6d5441bcdc3d2b30ff303266cefb9254
./frontend-audit/src/CookieConsent.jsx	d0dc77c4d32fa4353221f08a84746db0
./frontend-audit/src/HomePage.jsx	62cde73280c6f9f3871b8d3210ed0382
./frontend-audit/src/HyperliquidAgentApproval.tsx	60184ba0d9d0bd88b4360a23c7fee574
./frontend-audit/src/HyperliquidCommandParser.ts	535e395a38cadc9735ca2022763c0cae
./frontend-audit/src/HyperliquidResult.tsx	4c0761f50bd4516f0a937331624d2146
./frontend-audit/src/HyperliquidSign.tsx	ac089335ac004d2e08e311c0da2cd726
./frontend-audit/src/HyperliquidWithdrawalSign.tsx	49fde09716d1ed4d68d2424dd7d9a732
./frontend-audit/src/Input.tsx	72258d734b0ee28733d0b62314e8119b
./frontend-audit/src/input/buyCrypto.tsx	f10e80be942cd759dda9b6196e2aca8e
./frontend-audit/src/input/CommandHelper.tsx	c2aabe3f472598b15bcb314bb7e82844
./frontend-audit/src/input/CommandIcon.tsx	96fce7dbfcf4bc3efc414b1b593c0a5a
./frontend-audit/src/input/CommandInputField.tsx	ed9e7d91b0776c4a86fff8329782dffd
./frontend-audit/src/input/CommandPartsVisualizer.tsx	bf673b28ba171bb435402e7282cfc42b
./frontend-audit/src/input/CommandSuggestions.tsx	8099a79920a96c3952ef890cfe748ffe
./frontend-audit/src/input/CryptoLogoPreloader.ts	0ffd91a2082d73845cfe7af9a3fcf2ce
./frontend-audit/src/input/cryptoLogos.tsx	e4aec8b7923b6354b378d6a3b983a545
./frontend-audit/src/input/DepositPrompt.tsx	fa837eb14c179ab6c797a4e8eeafb216

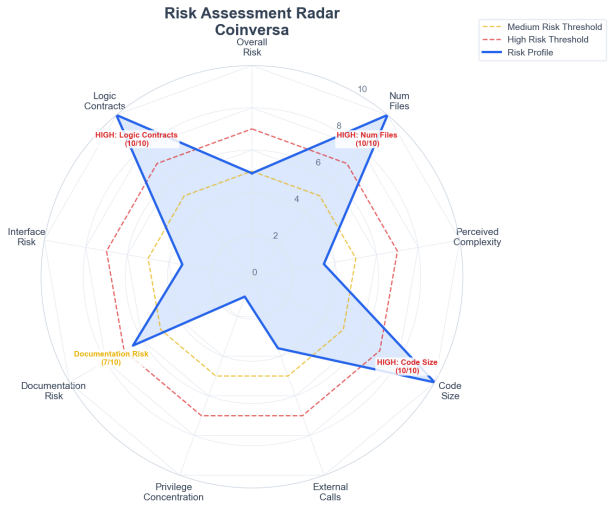
File	Fingerprint (MD5)
./frontend-audit/src/input/ParameterAutocomplete.tsx	ddad9dc8058b9a6f82be6d28a19bcd14
./frontend-audit/src/input/ParameterHintBadge.tsx	e67fb9c5861007e4139ebe1003ba5c98
./frontend-audit/src/input/useCommandInput.ts	d37605fcdfd1ec794904e69c9f44a573
./frontend-audit/src/input/useCommandParsing.ts	9403177ffcec553da373c01c73ecae2a
./frontend-audit/src/input/useHyperliquidData.ts	f52308f0d215e464eb5fdbcad1462d84
./frontend-audit/src/input/useHyperliquidMarketData.ts	32ec7d9b2ff0add7b40d346ea0087a85
./frontend-audit/src/input/useKeyboardNavigation.ts	4b4f54b703641ac328c288ed14326331
./frontend-audit/src/input/useTokenData.ts	e11d820b92cac1f7c15dde49c399303e
./frontend-audit/src/main.jsx	d088371427b3276da3f729f9a28a7cd3
./frontend-audit/src/NetworkModal.jsx	2a4144fa82f37356fc31083abc31e29c
./frontend-audit/src/Notifications.jsx	b1434b7d85af6435f2bec0579ee208aa
./frontend-audit/src/Payments.jsx	bc568366d6d9b8966fffe0cd0423717b
./frontend-audit/src/payments/AddBookmarkModal.jsx	77987ea44774fe05462678cdb507bed6
./frontend-audit/src/payments/PaymentDetail.jsx	aef635020550f5d38a868db58d6de477
./frontend-audit/src/Perps.tsx	62724b2ce5ca751de0097e9b38ff003b
./frontend-audit/src/perps/analytics/caculations.ts	acc4c32da4ac9920624baefd053ed91e
./frontend-audit/src/perps/analytics/CalendarPopup.tsx	f893d2d3bbdf660abb2942012b607970
./frontend-audit/src/perps/analytics/CoinLongShortCard.tsx	55561f6748418321618b88f961b8328b
./frontend-audit/src/perps/analytics/ExportTradesModal.tsx	66fa47b3f2da1992a3179bb58e1e8a36
./frontend-audit/src/perps/analytics/GlobalLongShortSection.tsx	c9f0d35825777d2bc933032cd29a0517
./frontend-audit/src/perps/analytics/hlPulse/CoinDetailPage.tsx	4d39f5642a9f3385d5ffeebddb834508
./frontend-audit/src/perps/analytics/hlPulse/CoinsSection.tsx	c61b220ff520c6f567242c4bd2571696
./frontend-audit/src/perps/analytics/hlPulse/DashboardSection.tsx	da52780e1254ff08dbbc09aa0749ba35
./frontend-audit/src/perps/analytics/hlPulse/LiquidationChart.tsx	a9591e769e227d40ee327f0f97a1a17d
./frontend-audit/src/perps/analytics/hlPulse/Pages.tsx	0904c2beed0b13f002823e8d72988a6f
./frontend-audit/src/perps/analytics/hlPulse/Search.tsx	3f4cc342237e7e25608d071c78c35572
./frontend-audit/src/perps/analytics/hlPulse/Sections.tsx	fef7eba6b9b074b62a0419c8555bcf60

File	Fingerprint (MD5)
./frontend-audit/src/perps/analytics/hlPulse/TraderProfilePage.tsx	dcd08f2879a8b8525a3662b59414df15
./frontend-audit/src/perps/analytics/hlPulse/TradersSection.tsx	3e7a48c37fcdf7cec5fbab8e547f3c2b
./frontend-audit/src/perps/analytics/hlPulse/types.ts	a4bbf969c98e55a1c83248b766e7e061
./frontend-audit/src/perps/analytics/hlPulse/UIComponents.tsx	9dca52e8dc50c276340bd0c4ea638c8c
./frontend-audit/src/perps/analytics/LongShortHeatmap.tsx	4de3aea6c40c7e006f52d6f71fa7849c
./frontend-audit/src/perps/analytics/LongShortRatioBar.tsx	6adad981042945bc36e02054e9c175d3
./frontend-audit/src/perps/analytics/PerformanceCalendar.tsx	b75697fec7f7a44d7bf46d3fcfeb62fc
./frontend-audit/src/perps/analytics/types.ts	e670a62bf98cac2858f396cf2106a15f
./frontend-audit/src/perps/AnalyticsTab.tsx	da33aa7831424dba083cf980d55645e7
./frontend-audit/src/perps/closePosition.tsx	9e1bfbf683886b1e11a97c1b34e29e7e
./frontend-audit/src/perps/FundingHeader.tsx	f1a28a26c581acf4dd28fb9f4f8a5b30
./frontend-audit/src/perps/Hlpulse.tsx	15c13593bf9027195a850a39f84169ef
./frontend-audit/src/perps/hooks/useTransactionExecutor.ts	186d8034bf59642cbeecaf2717d77167
./frontend-audit/src/perps/indicators.ts	2b6ff615136c46b7e632a76d06c1c6ce
./frontend-audit/src/perps/MarketHeader.tsx	d419fc767efee2d6e91fbfbc5e0c7bb9
./frontend-audit/src/perps/OrderBookTab.tsx	ad1f39211bbf6ac0c7d8b80cc7455cdb
./frontend-audit/src/perps/PerpCard.tsx	45d8f6f9b8ef41bcd10fbb537867daab
./frontend-audit/src/perps/PositionsFeed.tsx	6e8cd255778db613b99ab45489079a70
./frontend-audit/src/perps/PositionsTab.tsx	8a6726f68446e35366e7857f9baf9fb4
./frontend-audit/src/perps/QuickTradeModal.tsx	a7ec27341f605d5a5fd85f9c6066c6ac
./frontend-audit/src/perps/SendModal.tsx	b25e159b33c2f2315ee3e3ce44570409
./frontend-audit/src/perps/SymbolSelector.tsx	20ab8a6db2152796b027fe8c0c867080
./frontend-audit/src/perps/TPSLModal.tsx	8779cbdc6b5bdf49c7857d72d5236776
./frontend-audit/src/perps/TradesTab.tsx	c9dd1fc7467a6b0c45a856a291f2165e
./frontend-audit/src/perps/TradingButtons.tsx	176cc4e07fcbb9ccc560d536b98372a0
./frontend-audit/src/perps/TradingChart.tsx	e13ea06559d2830a130c51f7cb969275
./frontend-audit/src/perps/TradingPanel.tsx	5e8f39a9e236c69884449d272a151756

File	Fingerprint (MD5)
./frontend-audit/src/perps/types.ts	1a5eb89b7100b8c5730331003d348a54
./frontend-audit/src/perps/WalletAvatar.tsx	43bd4ee96db13177ce21bc8cad3e2ec6
./frontend-audit/src/perps/WithdrawModal.tsx	7823751c5e21df1f8779a02c827ce091
./frontend-audit/src/PrivyAuthSync.jsx	784673ff094c5f6fd35609dbb8007118
./frontend-audit/src/PrivyReauthPrompt.tsx	c31e2abe745ae3e2aae4e867092ce763
./frontend-audit/src/providers/CantonProvider.tsx	bd3f86893b10b40d848a2b8e9da8a91c
./frontend-audit/src/providers/Coinversaaloader.tsx	bed31394144df577d8fa82c8aeddb2ce
./frontend-audit/src/QuickActions.jsx	d50d2b2248b3e7136051d1ed4647b55a
./frontend-audit/src/Result.tsx	9f08762ed137d8333f4cbc78cc4752e9
./frontend-audit/src/Rewards.tsx	d4afd5b43b91aa3eedbedd849fa3294b
./frontend-audit/src/services/api.jsx	96d9a80cd0f5d358105ab4cba8a7bd7e
./frontend-audit/src/services/base64.ts	006ed707882215e801b34d77422f5301
./frontend-audit/src/services/hyperliquid.ts	bb0c887f04a53d2d53bcc6e7208419f1
./frontend-audit/src/services/importedTypes.ts	cca26381304bb16806e64a812c6fa1b7
./frontend-audit/src/services/intervals.ts	890cde64bb1448b9e7f546d1db2272c2
./frontend-audit/src/services/privyTokenManager.js	4a48aca4e08b10867280736a5bf973c0
./frontend-audit/src/services/thirdweb.jsx	db2b4211167fe0fd1f385c451b2b76ae
./frontend-audit/src/services/useHyperliquidWebSocket.ts	ec170cdea2fef9f8395752f95978c0d3
./frontend-audit/src/services/util.ts	1da0c112b9504f66d1695e76f69c7e52
./frontend-audit/src/Spinner.jsx	a541515fe7483d1ac7a069300f124058
./frontend-audit/src/StagingGate.jsx	dcf3e119d6f918c115fe96e22fc54d59
./frontend-audit/src/TradingSetupGuide.jsx	022e731e94d54f2ae93e8334e10db72a
./frontend-audit/src/TransactionList.jsx	d37fd56f5cecde6aa6093b0cd08b65c9
./frontend-audit/src/WalletPromptModal.jsx	9bd658416cdabaa1fcef7d2e13583d26
./frontend-audit/vite.config.js	6a6b807bd42c663bfa19a72909e57cbc

5.2 Source Lines & Risk





5.3 Dependencies / External Imports

Import Path	Version
@daml.js/daml-prim-DA-Types-1.0.0	-
@daml.js/ghc-stdlib-DA-Internal-Template-1.0.0	-
@daml/types	^3.4.8
@mojotech/json-type-validation	-
async_hooks	-
@solana/wallet-adapter-react-ui	^0.9.39
thirdweb	^5.93.9

5.4 Source Units in Scope

backend-audit

File	Instructions	Functions	Lines	nSLOC	Comments
api.ts	9	0	543	421	46
bot.ts	0	6	368	282	12
index.ts	0	0	3	2	1

File	Instructions	Functions	Lines	nSLOC	Comments
storage.ts	0	8	109	85	4
index.d.ts	0	0	1	1	0
module.d.ts	0	0	82	59	4
index.d.ts	0	0	1	1	0
module.d.ts	0	0	208	159	4
index.d.ts	0	0	1	1	0
module.d.ts	0	0	91	72	4
index.d.ts	0	0	1	1	0
module.d.ts	0	0	112	80	4
index.d.ts	0	0	8	8	0
index.d.ts	0	0	1	1	0
module.d.ts	0	0	19	12	4
index.d.ts	0	0	5	5	0
schema.d.ts	0	0	7147	4113	3033
validator-schema.d.ts	0	0	1296	1063	232
cantonService.ts	0	4	2773	2127	207
quests.ts	0	1	122	75	13
rewards.ts	0	0	54	22	20
captcha.ts	0	1	40	25	4
commands.ts	0	1	58	39	6
definitions.ts	0	8	936	715	108
hyperDefinitions.ts	0	11	1204	1027	67
types.ts	0	4	513	354	88
blockchainService.ts	0	5	1164	913	74
bridge.ts	0	6	294	225	13
chainConfig.ts	0	3	423	348	43
db.ts	0	1	37	21	10

File	Instructions	Functions	Lines	nSLOC	Comments
gcpLiveService.ts	0	5	1221	1038	42
hlpulseHistoricalService.ts	0	6	4275	3446	400
hyperliquidDepositService.ts	0	8	1509	1139	140
hyperliquidService.ts	0	6	4255	3172	483
hyperliquidStatsService.test.ts	0	3	378	282	36
hyperliquidStatsService.ts	0	1	553	413	61
hyperliquidWebSocket.ts	0	1	619	515	5
intervals.ts	0	4	46	32	6
lifi.ts	0	0	129	91	15
setupWebSocket.ts	0	1	89	69	2
tokens.ts	0	1	60	42	5
types.ts	0	0	27	20	1
util.ts	0	3	51	40	4
db.ts	0	2	144	101	13
email.ts	0	2	91	84	2
getVerifiedEmail.ts	0	1	33	19	9
index.ts	0	2	88	59	8
apiKeyAuth.ts	0	3	131	95	14
privyAuth.ts	0	1	112	81	18
stagingAuth.ts	0	1	48	35	5
strictPrivyAuth.ts	0	1	54	36	10
priceData.ts	0	12	415	290	54
privy.ts	0	3	120	99	2
cantonRoutes.ts	22	0	662	557	20
index.ts	6	1	415	338	33
index.ts	35	7	554	395	100
stagingAuth.ts	3	0	87	65	5

File	Instructions	Functions	Lines	nSLOC	Comments
index.ts	59	4	1285	1119	50
schemas.ts	0	0	26	16	0
index.ts	3	0	14	11	0
index.ts	27	6	566	477	36
index.ts	42	8	768	685	18
routes.ts	23	1	440	329	33
telegram-bot.ts	0	3	250	144	78
telegram-daily.ts	0	3	365	280	29
telegram-db.ts	0	1	80	58	8
util.ts	0	3	6	5	1
index.js	0	1	8	6	2
module.js	0	1	129	105	4
index.js	0	1	8	6	2
module.js	0	1	324	273	4
index.js	0	1	8	6	2
module.js	0	1	100	81	4
index.js	0	1	8	6	2
module.js	0	1	193	160	4
index.js	0	1	15	13	2
index.js	0	1	8	6	2
module.js	0	1	26	19	4
index.js	0	1	12	10	2

frontend-audit

File	Instructions	Functions	Lines	nSLOC	Comments
HyperliquidCommandParser.ts	0	1	817	548	153
commandParser.ts	0	3	964	713	116

File	Instructions	Functions	Lines	nSLOC	Comments
CryptoLogoPreloader.ts	0	1	447	324	49
useCommandInput.ts	0	8	1199	890	152
useCommandParsing.ts	0	1	92	72	9
useHyperliquidData.ts	0	1	196	160	16
useHyperliquidMarketData.ts	0	2	218	161	18
useKeyboardNavigation.ts	0	4	189	154	8
useTokenData.ts	0	10	1754	1429	96
caculations.ts	0	4	368	290	33
types.ts	0	16	448	367	30
types.ts	0	0	103	88	5
useTransactionExecutor.ts	0	7	350	253	40
indicators.ts	0	5	166	116	20
types.ts	0	0	133	87	33
base64.ts	0	2	14	11	0
hyperliquid.ts	0	4	61	55	0
importedTypes.ts	0	9	559	388	93
intervals.ts	0	1	124	112	6
useHyperliquidWebSocket.ts	0	2	486	397	10
util.ts	0	1	11	8	0
HyperliquidAgentApproval.tsx	0	10	724	561	60
HyperliquidResult.tsx	0	0	27	22	1
HyperliquidSign.tsx	0	21	2121	1797	116
HyperliquidWithdrawalSign.tsx	0	5	450	390	12
Input.tsx	0	12	1281	944	179
Perps.tsx	0	11	826	677	41
PrivyReauthPrompt.tsx	0	1	154	130	9
Result.tsx	0	31	1871	1592	83

File	Instructions	Functions	Lines	nSLOC	Comments
Rewards.tsx	0	16	1404	1206	91
CantonPartyId.tsx	0	1	34	29	0
SolanaProvider.tsx	0	0	28	23	1
CommandHelper.tsx	0	0	31	27	1
CommandIcon.tsx	0	0	41	38	1
CommandInputField.tsx	0	4	113	98	3
CommandPartsVisualizer.tsx	0	6	218	161	24
CommandSuggestions.tsx	0	3	156	126	3
DepositPrompt.tsx	0	15	688	603	32
ParameterAutocomplete.tsx	0	11	1328	1200	20
ParameterHintBadge.tsx	0	0	72	61	3
buyCrypto.tsx	0	0	89	82	2
cryptoLogos.tsx	0	2	124	104	7
AnalyticsTab.tsx	0	21	1700	1468	80
FundingHeader.tsx	0	4	364	318	9
HIpulse.tsx	0	3	508	393	47
MarketHeader.tsx	0	7	284	243	6
OrderBookTab.tsx	0	4	293	238	22
PerpCard.tsx	0	1	218	196	2
PositionsFeed.tsx	0	8	369	300	25
PositionsTab.tsx	0	10	1196	1067	14
QuickTradeModal.tsx	0	12	1049	901	57
SendModal.tsx	0	8	281	253	5
SymbolSelector.tsx	0	10	321	280	7
TPSLModal.tsx	0	9	609	517	34
TradesTab.tsx	0	2	172	146	6
TradingButtons.tsx	0	1	187	159	8

File	Instructions	Functions	Lines	nSLOC	Comments
TradingChart.tsx	0	10	1365	1207	61
TradingPanel.tsx	0	0	122	105	7
WalletAvatar.tsx	0	3	62	52	1
WithdrawModal.tsx	0	8	298	268	5
CalendarPopup.tsx	0	12	931	805	44
CoinLongShortCard.tsx	0	5	463	421	7
ExportTradesModal.tsx	0	6	458	401	17
GlobalLongShortSection.tsx	0	7	642	588	9
LongShortHeatmap.tsx	0	9	340	282	20
LongShortRatioBar.tsx	0	1	119	106	4
PerformanceCalendar.tsx	0	16	966	827	53
CoinDetailPage.tsx	0	11	1210	1089	33
CoinsSection.tsx	0	12	979	883	23
DashboardSection.tsx	0	12	930	794	49
LiquidationChart.tsx	0	18	669	588	16
Pages.tsx	0	1	104	90	9
Search.tsx	0	5	436	387	13
Sections.tsx	0	7	773	683	27
TraderProfilePage.tsx	0	37	3091	2717	130
TradersSection.tsx	0	0	171	142	12
UIComponents.tsx	0	5	434	369	28
closePosition.tsx	0	11	472	413	15
CantonProvider.tsx	0	29	1009	771	46
Coinversaaloader.tsx	0	10	461	417	4
chains.config.js	0	5	620	261	345
privyTokenManager.js	0	3	53	27	20
AccountsView.jsx	0	10	411	363	11

File	Instructions	Functions	Lines	nSLOC	Comments
App.jsx	0	2	86	72	3
AppLayout.jsx	0	4	150	121	8
AppNavigation.jsx	0	6	297	257	10
ChainLogo.jsx	0	2	81	68	6
Command.jsx	0	21	1188	1002	58
CommandBar.jsx	0	2	111	99	3
ConnectedWallets.jsx	0	20	1669	1143	385
CookieConsent.jsx	0	9	179	142	19
HomePage.jsx	0	33	1482	1284	61
NetworkModal.jsx	0	4	233	207	5
Notifications.jsx	0	19	1074	921	48
Payments.jsx	0	9	264	227	12
PrivyAuthSync.jsx	0	1	49	30	12
QuickActions.jsx	0	1	65	62	0
Spinner.jsx	0	1	27	24	0
StagingGate.jsx	0	2	325	307	2
TradingSetupGuide.jsx	0	6	525	457	15
TransactionList.jsx	0	29	1066	954	38
WalletPromptModal.jsx	0	10	607	517	21
Spinner.jsx	0	1	27	24	0
main.jsx	0	0	12	8	0
AddBookmarkModal.jsx	0	6	341	303	11
PaymentDetail.jsx	0	16	1050	972	15
api.jsx	0	6	141	92	25
thirdweb.jsx	0	5	196	148	16

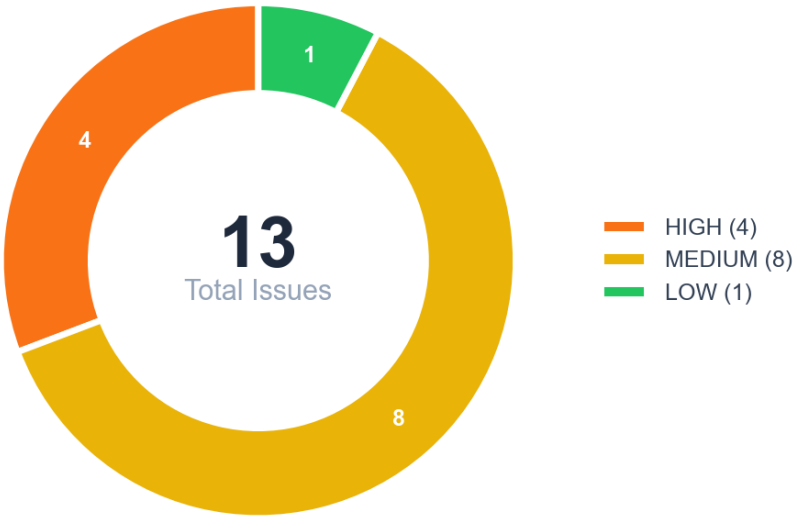
Total (all codebases): 229 instructions, 974 functions, 95283 lines, 76095 nSLOC

6. Scope of Work

This audit covers the Coinversa backend API (Express/TypeScript) and frontend application (React/JSX). The backend handles authentication via Privy, trading execution through the Hyperliquid API, Canton ledger integration, WebSocket market data streaming, and PostgreSQL persistence. The frontend provides the trading interface, wallet management, Canton identity passkey handling, and notification system. The assessment was performed as a whitebox source code security review with full access to the codebase.

6.1 Findings Overview

Findings are classified by severity: Critical, High, Medium, Low, and Informational.



No	Title	Severity	Status
6.2.1	privyAuth GET Bypass: Inconsistent Auth Model	HIGH	FIXED
6.2.2	privyAuth No Ownership Check: Trading IDOR	HIGH	FIXED
6.2.3	Hardcoded PostgreSQL Credentials in Fallback Connection String	HIGH	FIXED
6.2.4	Notifications.jsx innerHTML XSS (Stored XSS Vector)	HIGH	FIXED

No	Title	Severity	Status
6.2.5	Canton Passkey Secret Stored Unencrypted in localStorage	MEDIUM	FIXED
6.2.6	Missing Security Hardening Middleware	MEDIUM	FIXED
6.2.7	JWT Tokens Never Expire	MEDIUM	FIXED
6.2.8	HTML Injection in Email Bodies	MEDIUM	FIXED
6.2.9	WebSocket No maxPayload Limit (DoS Risk)	MEDIUM	FIXED
6.2.10	Auth Tokens in localStorage (Session Theft Risk)	MEDIUM	FIXED
6.2.11	Vulnerable Dependencies: Backend (121 CVEs, 6 Critical)	MEDIUM	FIXED
6.2.12	Vulnerable Dependencies: Frontend (95 CVEs, 4 Critical)	MEDIUM	FIXED
6.2.13	Express X-Powered-By Header Disclosure	LOW	FIXED

6.2 Manual and Automated Vulnerability Test

6.2.1 privyAuth GET Bypass: Inconsistent Auth Model

HIGH FIXED

DESCRIPTION

The `privyAuth` middleware explicitly bypasses token verification for all GET, HEAD, and OPTIONS requests. While the currently affected GET endpoints (`/account/:address`, `/positions/:address`, `/orders/:address`, `/pnl/:address`, `/funding-history/:address`) are wrappers around `hyperliquidService.infoClient.*` — a proxy to the Hyperliquid public info API that requires no authentication — the inconsistent auth model creates a maintenance risk. If any future GET route returns Coinversa-internal data (user preferences, internal IDs, agent wallet mappings) that is not on-chain, it would silently inherit the bypass and become exploitable.

CODE LOCATION

`backend-audit/src/middleware/privyAuth`

```
const readOnlyMethods = ['GET', 'HEAD', 'OPTIONS'];
if (readOnlyMethods.includes(req.method.toUpperCase())) {
  return next(); // token check skipped for all GET requests
}
```

RECOMMENDATION

Separate public market-data proxies from user-specific routes at the router level rather than relying on the HTTP-method bypass in middleware:

```
// Public — market data, candles, assets (no auth needed by design)
router.use('/market', publicHyperliquidRouter);

// User-specific — always require token regardless of HTTP method
router.use('/hyperliquid', strictPrivyAuth, hyperliquidRouter);
```

6.2.2 privyAuth No Ownership Check: Trading IDOR

HIGH FIXED

DESCRIPTION

After verifying the Privy JWT, `privyAuth` sets `req.privyUser.userId` but never asserts that target wallet fields in the request (`address`, `masterAddress`, `fromAddress`) belong to that authenticated user. Once a valid token is present, User A can supply User B's wallet in request fields and the middleware still passes the request to trading handlers. That enables order placement, position actions, leverage changes, withdrawal preparation, or agent operations on behalf of another wallet — a classic Insecure Direct Object Reference (IDOR) on protected POST endpoints under `/api/v1/hyperliquid/`.

CODE LOCATION

`backend-audit/src/middleware/privyAuth`

```
const claims = await privy.verifyAuthToken(token);
req.privyUser = { userId: claims.userId, ... };
// No ownership check against req.privyUser before next()
next();
```

RECOMMENDATION

After verifying the JWT, resolve the Privy userId to their registered wallet address(es) and assert that all target wallet fields match before calling `next()`.

```
const targets = [req.body.address, req.body.masterAddress,
req.body.fromAddress].filter(Boolean);
if (targets.some((a) => a !== req.privyUser.walletAddress)) {
  return res.status(403).json({ error: 'Forbidden: address mismatch' });
}
```

6.2.3 Hardcoded PostgreSQL Credentials in Fallback Connection String

HIGH FIXED

DESCRIPTION

The PostgreSQL connection pool is initialised with a hardcoded fallback connection string that contains live database credentials. While the code prefers `process.env.POSTGRES_CONNECT_URI` when set, the fallback contains the real production credentials. These credentials are permanently in git history. During this audit the hardcoded connection string was tested directly — the database host is not reachable (connection timed out). This reduces immediate exploitability but does not eliminate the risk: network configurations can change, and the credentials remain exposed in git history.

CODE LOCATION

`backend-audit/src/crypto/db.ts:5`

```
export const pool = new Pool({
  connectionString: process.env.POSTGRES_CONNECT_URI || 'postgresql://
***:***@***.***.***.***:5432/***',
  //                                                    hardcoded user, password,
and host as fallback
  max: 100,
});
```

RECOMMENDATION

Immediately rotate the PostgreSQL password — treat it as compromised since it is in git history. Remove the hardcoded fallback entirely:

Purge the credentials from git history using `git filter-repo` or BFG Repo-Cleaner. Add Gitleaks as a pre-commit hook: `gitleaks protect --staged`.

```
const connectionString = process.env.POSTGRES_CONNECT_URI;
if (!connectionString) throw new Error('POSTGRES_CONNECT_URI not set');
export const pool = new Pool({ connectionString, max: 100 });
```

6.2.4 Notifications.jsx innerHTML XSS (Stored XSS Vector)

HIGH FIXED

DESCRIPTION

The `Notifications.jsx` toast renderer builds the notification DOM by setting `toast.innerHTML` to a template literal that directly includes the `message` variable, which is populated from server-provided API error responses (`data.error`). There is no `DOMPurify.sanitize()` call or any other sanitization before the assignment. If the backend returns an error string containing `<img src=x onerror=alert(1)>`, the payload executes in the user's browser context. Combined with auth tokens stored in localStorage, this is a complete session-theft vector.

CODE LOCATION

`frontend-audit/src/Notifications.jsx`

```
toast.innerHTML = `
    <span class="n-toast-icon">${type === 'success' ? '✓' : type === 'error' ?
'×' : 'ℹ'}</span>
    <span>${message}</span>
`;
```

RECOMMENDATION

Also switch the icon span to use `textContent` rather than `innerHTML` since it contains only a single character.

```
import DOMPurify from 'dompurify';
toast.innerHTML = DOMPurify.sanitize(`<span class="n-toast-icon">...</span><span>$
{message}</span>`);
```

6.2.5 Canton Passkey Secret Stored Unencrypted in localStorage

MEDIUM FIXED

DESCRIPTION

A passkey-derived cryptographic secret (`coinversaa-id-secret`) is stored unencrypted in `localStorage`. The developer left a TODO comment directly above the storage call acknowledging this is insecure. This secret is readable by any JavaScript on the page, including injected XSS payloads, third-party scripts, and session recording SDKs. Theft of this secret compromises the user's Canton distributed ledger identity.

CODE LOCATION

`frontend-audit/src` (Canton identity module)

```
// TODO: Encrypt this with a server-side secret stored in an http-only cookie.
// That way this can stay decrypted in memory without leaking any data.
localStorage.setItem(secretStorageName, uint8ToBase64(secret))
```

RECOMMENDATION

Implement the developer's own TODO: derive an encryption key from a server-side secret delivered as an `httpOnly SameSite=Strict` cookie, then AES-GCM encrypt the passkey secret before writing it to storage. Alternatively, store the secret only in session memory (a React ref or context state) and require re-authentication after a page reload.

6.2.6 Missing Security Hardening Middleware

MEDIUM FIXED

DESCRIPTION

The Express backend is missing all standard security hardening middleware: no `helmet` (X-Powered-By header leaks Express framework/version, no Content-Security-Policy, HSTS, X-Frame-Options), no `express-rate-limit` (no brute-force protection), no `express-slow-down`, no `hpp` (HTTP parameter pollution), and `bodyParser.json({ limit: '10mb' })` is extremely permissive for a trading API.

CODE LOCATION

`backend-audit/src/routes.ts`

```
app.use(morgan('dev'))
app.use(cors(corsOptions))
app.use(cookieParser())
app.use(bodyParser.json({ limit: '10mb' }))
// no helmet, no rate-limit, no hpp, no slow-down
```

```
import helmet from 'helmet';
import rateLimit from 'express-rate-limit';
import hpp from 'hpp';

app.use(helmet());
app.use(hpp());

const tradingLimiter = rateLimit({ windowMs: 60 * 1000, max: 60 });
app.use('/api/v1/hyperliquid', tradingLimiter);

app.use(bodyParser.json({ limit: '1mb' }));
```

6.2.7 JWT Tokens Never Expire

MEDIUM FIXED

DESCRIPTION

`jwt.sign()` is called without an `expiresIn` option in `cantonService.ts`. Tokens created without an expiry never expire.

CODE LOCATION

`backend-audit/src/canton/cantonService.ts:295`

```
const payload = this.createTokenPayload(allParties);
return jwt.sign(payload, jwtSecret);
//                                  no expiresIn option
```

RECOMMENDATION

Add a short expiry to every `jwt.sign()` call:

For long-lived sessions, use a refresh-token pattern. Also consider storing issued tokens in a short-lived Redis cache so individual tokens can be revoked without rotating the signing key.

```
return jwt.sign(payload, jwtSecret, { expiresIn: '1h' });
```

6.2.8 HTML Injection in Email Bodies

MEDIUM FIXED

DESCRIPTION

The `/register-interest` endpoint and developer API access request handler interpolate user-supplied `name`, `email`, and `reasonForInterest` fields directly into HTML email templates sent to the admin mailbox. An attacker who submits registration interest with HTML/CSS in these fields will inject arbitrary markup into the admin's email client. While email clients generally strip `<script>` tags, HTML injection can be used for phishing, layout manipulation, or tracking pixel injection.

CODE LOCATION

`backend-audit/src/routes.ts:118`, `141-143`, `204`

```
`<h1> Hey ${name}, you've registered on the Coinversa whitelist. </h1>`

`<p>Name: ${name}</p>
```

```
 <p>Email: ${email}</p>
 <p>Reason they're interested: ${reasonForInterest}</p>`
```

RECOMMENDATION

HTML-escape all user values before interpolation:

```
function escHtml(s: string): string {
  return String(s)
    .replace(/&/g, '&amp;')
    .replace(/</g, '&lt;')
    .replace(/>/g, '&gt;')
    .replace(/"/g, '&quot;');
}

`<p>Name: ${escHtml(name)}</p>
 <p>Email: ${escHtml(email)}</p>
 <p>Reason: ${escHtml(reasonForInterest)}</p>`
```

6.2.9 WebSocket No maxPayload Limit (DoS Risk)

MEDIUM FIXED

DESCRIPTION

The `/ws/hyperliquid` WebSocket server is created without a `maxPayload` option. The default `ws` library behaviour is to accept frames of unlimited size. A client can send a single very large frame (hundreds of MB) and exhaust the server's heap memory, causing a crash or severe performance degradation. No authentication is needed — the endpoint serves public market data and is intentionally open.

CODE LOCATION

`backend-audit/src/crypto/setupWebSocket.ts:9`

```
const wss = new WebSocket.Server({
  server,
  path: '/ws/hyperliquid',
  // no maxPayload option; unlimited frame size accepted
});
```

RECOMMENDATION

Also consider adding a connection-per-IP limit using a `Map<string, number>` counter in the connection handler.

```
const wss = new WebSocket.Server({
  server,
  path: '/ws/hyperliquid',
  maxPayload: 64 * 1024,  // 64 KB
});
```

6.2.10 Auth Tokens in localStorage (Session Theft Risk)

MEDIUM FIXED

DESCRIPTION

Auth tokens (`accessToken`, `privy:token`) are stored in `localStorage`, making them readable by any JavaScript on the page. `api.jsx` reads `localStorage.getItem("accessToken")` for outbound auth and will write `localStorage.setItem('accessToken', authHeader)` if an Authorization response header is present (no validation). The `@microsoft/clarity` session recording SDK is installed in `package.json` and has read access to all localStorage keys, including these tokens. Any XSS payload (e.g., via H-04) can exfiltrate the current session without further privilege escalation.

CODE LOCATION

`frontend-audit/src/api.jsx`, `frontend-audit/src/privyTokenManager.js`

RECOMMENDATION

Move auth tokens to `httpOnly SameSite=Strict` cookies so JavaScript cannot read them. If localStorage is unavoidable short-term, implement a Content Security Policy (CSP) to block inline scripts and restrict third-party domains, and audit all third-party scripts (including Clarity) for data collection scope.

6.2.11 Vulnerable Dependencies: Backend (121 CVEs, 6 Critical)

MEDIUM FIXED

DESCRIPTION

121 CVEs found across 90 packages (6 critical, 58 high, 37 medium, 20 low). Critical packages `pbkdf2`, `sha.js`, `elliptic` are cryptographic libraries — vulnerabilities in these carry elevated risk given the blockchain/trading context.

CODE LOCATION

`backend-audit/bun.lock`

RECOMMENDATION

Run `bun audit --fix` or `npm audit fix` to auto-upgrade packages where non-breaking fixes are available. For packages requiring major version bumps, schedule dedicated upgrade sprints. Add `bun audit --audit-level=critical` as a CI gate that fails the build on any new critical CVE. Add OSV-Scanner to the CI pipeline: `osv-scanner --lockfile backend-audit/bun.lock --fail-on-severity critical`.

6.2.12 Vulnerable Dependencies: Frontend (95 CVEs, 4 Critical)

MEDIUM FIXED

DESCRIPTION

95 CVEs found across 65 packages (4 critical, 46 high, 43 medium, 2 low).

CODE LOCATION

`frontend-audit/package-lock.json`

RECOMMENDATION

Run `npm audit fix` in `frontend-audit/` and integrate `npm audit --audit-level=critical` into the CI pipeline. Prioritise upgrades for packages directly used in auth, data rendering, and file/export operations.

6.2.13 Express X-Powered-By Header Disclosure

LOW FIXED

DESCRIPTION

Express sends `X-Powered-By: Express` in every HTTP response by default. This header advertises the framework to any observer, reducing the cost of reconnaissance for an attacker. While not an exploitable vulnerability on its own, it violates the principle of minimal information disclosure and is trivially fixed as a side-effect of installing `helmet` (M-02).

CODE LOCATION

`backend-audit/src/routes.ts`

```
HTTP/1.1 200 OK
X-Powered-By: Express    ← reveals framework
Content-Type: application/json
```

RECOMMENDATION

Installing `helmet` (recommended in M-02) disables this header automatically. Alternatively, disable it explicitly:

```
app.disable('x-powered-by');
```

7. Executive Summary

Two independent softstack experts performed an unbiased and isolated audit of the frontend and backend codebase provided by the Coinversa team. The main objective of the audit was to verify the security and functionality claims of the frontend and backend codebase. The audit process involved a thorough manual code review and automated security testing.

Overall, the audit identified a total of 13 issues, classified as follows:

- No critical issues were found
- 4 high severity issues were found
- 8 medium severity issues were found
- 1 low severity issue was found
- No informational issues were found

The Coinversa team has successfully addressed all identified issues from the audit. All vulnerabilities have been mitigated based on the recommendations provided in the report. A follow-up review confirms that the fixes have been implemented effectively, ensuring the security and functionality of the frontend and backend codebase.

8. About the Auditor

Established in 2017 under the name Chainsulting, and rebranded as softstack GmbH in 2023, softstack has been a trusted name in Web3 Security space. Within the rapidly growing Web3 industry, softstack provides a comprehensive range of offerings that include software development, cybersecurity, and consulting services. Softstack's competency extends across the security landscape of prominent blockchains like Solana, Tezos, TON, Ethereum and Polygon. The company is widely recognized for conducting thorough code audits aimed at mitigating risk and promoting transparency.

The firm's proficiency lies particularly in assessing and fortifying smart contracts of leading DeFi projects, a testament to their commitment to maintaining the integrity of these innovative financial platforms. To date, softstack plays a crucial role in safeguarding over $100 billion worth of user funds in various DeFi protocols.

Underpinned by a team of industry veterans possessing robust technical knowledge in the Web3 domain, softstack offers industry-leading smart contract audit services. Committed to evolving with their clients' ever-changing business needs, softstack's approach is as dynamic and innovative as the industry it serves.

Check our website for further information: https://softstack.io

9. Glossary

Term	Definition
CORS	Cross-Origin Resource Sharing
CSP	Content Security Policy
CVE	Common Vulnerabilities and Exposures
CVSS	Common Vulnerability Scoring System
Canton	A privacy-enabled distributed ledger protocol by Digital Asset
DoS	Denial of Service
HSTS	HTTP Strict Transport Security
Hyperliquid	A decentralized perpetual exchange
IDOR	Insecure Direct Object Reference
JWT	JSON Web Token
OWASP	Open Web Application Security Project
Privy	Authentication-as-a-service provider for Web3 applications
SAST	Static Application Security Testing
XSS	Cross-Site Scripting